

EShop — Bug Report

Bugs found by executing the domain-testing + BVA suite (docs/test-design-report.md , 124 cases) plus supplemental gap cases (FR10-ADM-01 , FR10-SEC-01 , FR14-INTEG-01), against the backend at commit 6cdd618 . **Oracle** = README.md . Each bug traces to failing case IDs in docs/test-results.md and tests/results.json .

17 bugs across 17 GitHub issues — **2 Critical · 7 High · 2 Medium · 6 Low**. Severity-ordered. (The former GUI bundle BUG-11 was split into 5 separate issues: BUG-11 + BUG-14...17.)

#	Sev	Feature	Title	Cases	Issue
BUG-04	Critical	FR-05	SQL injection & LIKE-wildcard leak in product search	5	#1
BUG-10	Critical	FR-05	Reflected XSS in web search (dangerouslySetInnerHTML)	4	#10
BUG-01	High	FR-09	Coupon rejected when total exactly equals the minimum (> vs >=)	5	#2
BUG-02	High	FR-09	Percent discount formula wrong → negative discount	3	#3
BUG-03	High	FR-09	Coupon applies without login (C4 not enforced)	1	#4
BUG-06	High	FR-14	Category write endpoints accept a non-admin token (SEC-03)	3	#5
BUG-07	High	FR-10	Server lets a user cancel a shipping order	2	#6
BUG-08	High	FR-10	Admin can move a canceled order to delivered (final-state)	1	#8
BUG-13	High	FR-10	Non-admin can change order status (missing role check, SEC-03)	1	#13
BUG-05	Medium	FR-14	Empty / whitespace category name accepted	4	#7
BUG-09	Medium	FR-14	Deleting a category orphans its products (FR-15 integrity)	1	#9
BUG-11	Low	FR-05	Listing page has two <h1> (should be exactly one)	1	#11
BUG-14	Low	FR-05	Product images have empty alt attribute	1	#15
BUG-15	Low	FR-05	Price shows "VND" instead of the ₫ symbol	1	#16
BUG-16	Low	FR-05	No loading state while fetching products	1	#17
BUG-17	Low	FR-05	No empty-state message when search returns no results	1	#18
BUG-12	Low	FR-09	Coupon code lookup is case-sensitive (save10 ≠ SAVE10)	1	#12

Environment (all bugs): backend http://localhost:3000 , seed DB (fresh on boot). Accounts: admin admin@eshop.com/Admin123! , user test@eshop.com/Test1234! (id 2). **Screenshots:** each bug's evidence image is embedded in its section below from evidence/bug-0X.png (the same screenshots are attached to the corresponding GitHub issues).

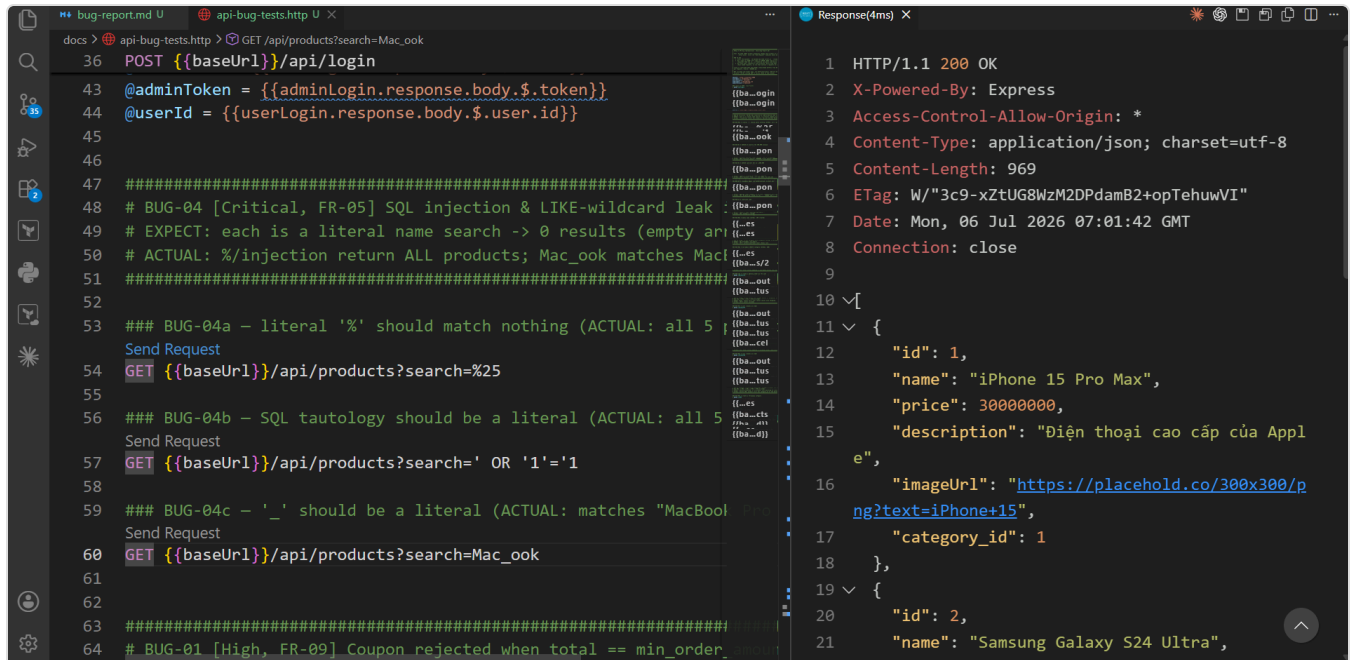
BUG-04 — [FR-05] SQL injection & LIKE-wildcard leak in product search

- **Severity:** Critical

- **Spec:** FR-05 R4 (search **by name**), R5 (term rendered safely), **SEC-05** (parameterised queries — no string concatenation), SEC-04.
- **Preconditions:** seed DB (5 products).
- **Steps (cURL):**

```
curl -s "http://localhost:3000/api/products?search=%25" # %25 = a literal '%'
curl -s "http://localhost:3000/api/products?search=' OR '1'='1'"
curl -s "http://localhost:3000/api/products?search=Mac_ook"
```

- **Expected:** each is a *literal* name search → **0 results** (no product name contains %, ' OR '1'='1', or Mac_ook).
- **Actual:** % → **all 5 products**; ' OR '1'='1' → **all 5**; Mac_ook → **MacBook Pro M3** (the _ acted as a SQL wildcard). The query is built by string concatenation, so %, _, ' are interpreted as SQL, not treated as literals — a working SQL-injection / data-leak vector.
- **Evidence:**



- **Traceability:** FR05-DT-12, FR05-DT-13, FR05-BVA-10, FR05-BVA-11, FR05-BVA-12.

BUG-01 — [FR-09] Coupon rejected when order total exactly equals the minimum

- **Severity:** High
- **Spec:** FR-09 C3 — "Tổng đơn hàng >= (lớn hơn hoặc bằng) min_order_amount".
- **Preconditions:** logged-in user (id 2); coupon SAVE10 (min 300,000).
- **Steps (cURL):**

```
curl -s -X POST http://localhost:3000/api/apply-coupon \
-H "Content-Type: application/json" \
-d '{"code":"SAVE10","total_amount":300000,"user_id":2}'
```

- **Expected:** coupon **applies** at exactly the minimum (discount 30,000; final 270,000).
- **Actual:** 400 {"error":"Đơn hàng chưa đủ giá trị tối thiểu 300,000 đ ..."} . The check uses total_amount > min_order_amount (strict >) instead of >=, so an order *equal* to the minimum is wrongly rejected. Reproduced for BIGBUY (500,000) and VIP100 (300,000).

- **Evidence:**

```
61
62
63 #####
64 # BUG-01 [High, FR-09] Coupon rejected when tot
65 # EXPECT: 200 apply; discount 30,000; final 270
66 # ACTUAL: 400 "Đơn hàng chưa đủ giá trị tối thi
67 #####
68
69 ### BUG-01 - SAVE10 at exactly the 300,000 mini
Send Request
70 POST {{baseUrl}}/api/apply-coupon
71 Content-Type: application/json
72
73 { "code": "SAVE10", "total_amount": 300000, "us
74
75
76 #####

1 HTTP/1.1 400 Bad Request
2 X-Powered-By: Express
3 Access-Control-Allow-Origin: *
4 Content-Type: application/json; charset=utf-8
5 Content-Length: 98
6 ETag: W/"62-zdGIVV8U4NM1Wd7cz+6q0pgXVo"
7 Date: Mon, 06 Jul 2026 07:02:54 GMT
8 Connection: close
9
10 {
11   "error": "Đơn hàng chưa đủ giá trị tối thiểu 30
    0,000 đ để áp dụng mã này"
12 }
```

- **Traceability:** FR09-BVA-02 , FR09-BVA-05 , FR09-BVA-08 , FR09-DT-01 , FR09-DT-02 .

BUG-02 — [FR-09] Percent discount formula wrong → negative discount / inflated total

- **Severity:** High
- **Spec:** FR-09 — percent: $\text{discount_amount} = \text{total} \times \text{discount_value} / 100$; $\text{final_amount} = \text{total} - \text{discount_amount}$.
- **Preconditions:** logged-in user; coupon SAVE10 (percent 10).
- **Steps (cURL):**

```
curl -s -X POST http://localhost:3000/api/apply-coupon \
-H "Content-Type: application/json" \
-d '{"code":"SAVE10","total_amount":1000000,"user_id":2}'
```

- **Expected:** discount 100,000; final 900,000.
- **Actual:** 200 {"discount_amount":-900000,"final_amount":1000000} . The code computes $\text{discount} = \text{floor}(\text{total} \times (1 - \text{discount_value}))$ (treating $\text{discount_value}=10$ as a fraction), producing a large **negative** discount and a final **larger** than the order total.
- **Evidence:**

```
#####
# BUG-02 [High, FR-09] Percent formula wrong -> negative discount
# EXPECT: discount 100,000; final 900,000 (10% of 1,000,000)
# ACTUAL: 200 {"discount_amount":-900000,"final_amount":1000000}
#####

### BUG-02 - SAVE10 (percent 10) on 1,000,000
Send Request
POST {{baseUrl}}/api/apply-coupon
Content-Type: application/json

{ "code": "SAVE10", "total_amount": 1000000, "user_id": {{userId}} }

#####
# BUG-03 [High, FR-09] Coupon applies without login (C4 not enforced)
# EXPECT: reject - a valid JWT/login is required

3 Access-Control-Allow-Origin: *
4 Content-Type: application/json; charset=utf-8
5 Content-Length: 129
6 ETag: W/"81-5DpU3sm3cavdaQU6lhP1yE7hd0E"
7 Date: Mon, 06 Jul 2026 07:05:20 GMT
8 Connection: close
9
10 {
11   "success": true,
12   "coupon_id": 1,
13   "discount_amount": -900000,
14   "final_amount": 1000000,
15   "message": "Áp dụng thành công! Giảm 10%"
16 }
```

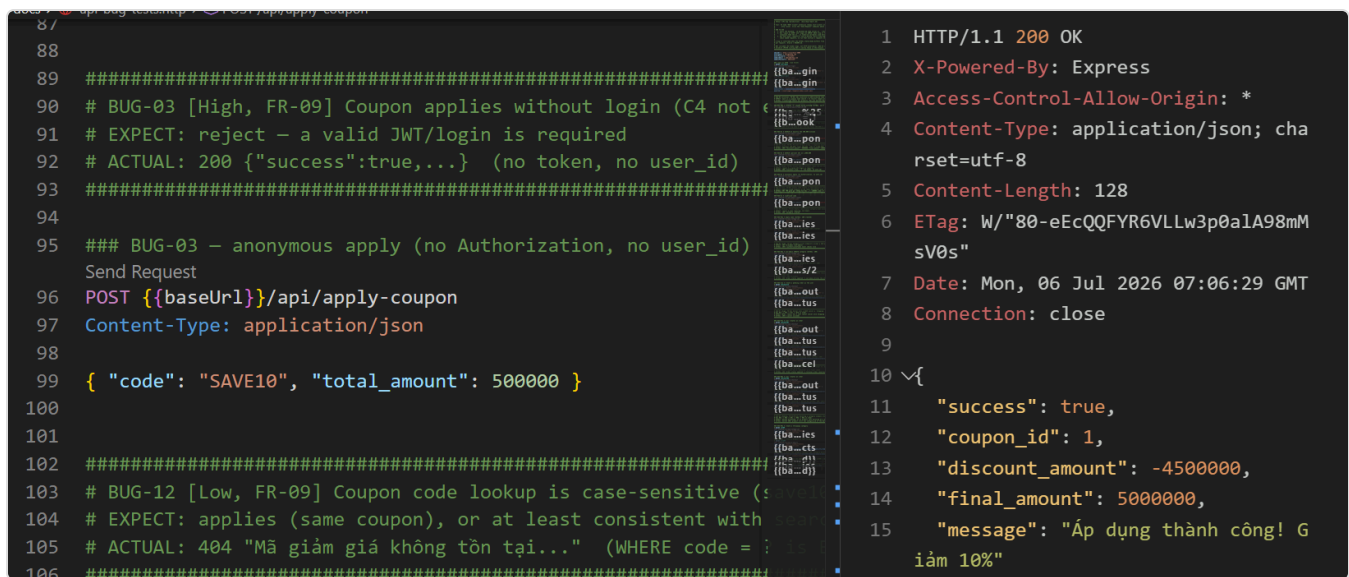
- **Traceability:** FR09-DT-17 , FR09-BVA-03 , FR09-BVA-22 .

BUG-03 — [FR-09] Coupon applies without login (C4 not enforced)

- **Severity:** High
- **Spec:** FR-09 **C4** (user must be logged in) / **SEC-02** (secured APIs require a valid JWT).
- **Preconditions:** none (anonymous).
- **Steps (cURL):**

```
curl -s -X POST http://localhost:3000/api/apply-coupon \
-H "Content-Type: application/json" \
-d '{"code":"SAVE10","total_amount":500000}' # no token, no user_id
```

- **Expected:** reject — a valid login/JWT is required (C4).
- **Actual:** 200 {"success":true,...} — the coupon is applied for an anonymous request. The endpoint has no auth middleware and treats `user_id` as optional, which also **bypasses the per-user usage cap (C5)** since usage cannot be attributed.
- **Evidence:**



```
87
88
89 #####
90 # BUG-03 [High, FR-09] Coupon applies without login (C4 not e
91 # EXPECT: reject - a valid JWT/login is required
92 # ACTUAL: 200 {"success":true,...} (no token, no user_id)
93 #####
94
95 ### BUG-03 - anonymous apply (no Authorization, no user_id)
96 Send Request
97 POST {{baseUrl}}/api/apply-coupon
98 Content-Type: application/json
99 { "code": "SAVE10", "total_amount": 500000 }
100
101
102 #####
103 # BUG-12 [Low, FR-09] Coupon code lookup is case-sensitive (s
104 # EXPECT: applies (same coupon), or at least consistent with
105 # ACTUAL: 404 "Mã giảm giá không tồn tại..." (WHERE code = ;
106 #####
```

```
1 HTTP/1.1 200 OK
2 X-Powered-By: Express
3 Access-Control-Allow-Origin: *
4 Content-Type: application/json; cha
  rset=utf-8
5 Content-Length: 128
6 ETag: W/"80-eEcQQFYR6VLLw3p0a1A98mM
  sV0s"
7 Date: Mon, 06 Jul 2026 07:06:29 GMT
8 Connection: close
9
10 {
11   "success": true,
12   "coupon_id": 1,
13   "discount_amount": -4500000,
14   "final_amount": 5000000,
15   "message": "Áp dụng thành công! G
    iảm 10%"
```

- **Traceability:** FR09-DT-09 (and see BUG-01 note re FR09-DT-16).

BUG-06 — [FR-14] Category write endpoints accept a non-admin token (missing role check)

- **Severity:** High
- **Spec:** FR-12 / **SEC-03** — admin APIs and `POST/PUT/DELETE /api/categories` must require a valid JWT **and** `role='admin'`, not merely the presence of a token.
- **Preconditions:** log in as the normal user to get a non-admin token.
- **Steps (cURL):**

```
TOKEN=$(curl -s -X POST http://localhost:3000/api/login -H "Content-Type: application/json" \
-d '{"email":"test@eshop.com","password":"Test1234!"}' | sed -E 's/.*"token":"([^\"]+).*/\1/')
curl -s -o /dev/null -w "%{http_code}\n" -X POST http://localhost:3000/api/categories \
-H "Authorization: Bearer $TOKEN" -H "Content-Type: application/json" -d '{"name":"Hacked"}'
curl -s -o /dev/null -w "%{http_code}\n" -X DELETE http://localhost:3000/api/categories/2 \
-H "Authorization: Bearer $TOKEN"
```

- **Expected:** 403 Forbidden (non-admin).
- **Actual:** 200 for both create and delete. `authenticateToken` verifies the JWT but never checks `role`, so any logged-in user can manage categories.
- **Evidence:**

```

6 #####
7 # BUG-06 [High, FR-14] Category write endpoints accept
8 # EXPECT: 403 Forbidden (non-admin)
9 # ACTUAL: 200 — authenticateToken never checks role
10 #####
11
12 ### BUG-06a — non-admin CREATE category (ACTUAL: 200)
13 Send Request
14 POST {{baseUrl}}/api/categories
15 Authorization: Bearer {{userToken}}
16 Content-Type: application/json
17
18 { "name": "Hacked-by-user" }
19
20 ### BUG-06b — non-admin DELETE category #2 (ACTUAL: 200)
21
22 #####
23
24 #####
25
26 #####
27
28 #####
29
30 #####
31
32 #####
33
34 #####
35
36 #####
37
38 #####
39
40 #####
41
42 #####
43
44 #####
45
46 #####
47
48 #####
49
50 #####
51
52 #####
53
54 #####
55
56 #####
57
58 #####
59
60 #####
61
62 #####
63
64 #####
65
66 #####
67
68 #####
69
70 #####
71
72 #####
73
74 #####
75
76 #####
77
78 #####
79
80 #####
81
82 #####
83
84 #####
85
86 #####
87
88 #####
89
90 #####
91
92 #####
93
94 #####
95
96 #####
97
98 #####
99
100 #####
101
102 #####
103
104 #####
105
106 #####
107
108 #####
109
110 #####
111
112 #####
113
114 #####
115
116 #####
117
118 #####
119
120 #####
121
122 #####
123
124 #####
125
126 #####
127
128 #####
129
130 #####
131
132 #####
133
134 #####
135
136 #####
137
138 #####
139
140 #####
141
142 #####
143
144 #####
145
146 #####
147
148 #####
149
150 #####
151
152 #####
153
154 #####
155
156 #####
157
158 #####
159
160 #####
161
162 #####
163
164 #####
165
166 #####
167
168 #####
169
170 #####
171
172 #####
173
174 #####
175
176 #####
177
178 #####
179
180 #####
181
182 #####
183
184 #####
185
186 #####
187
188 #####
189
190 #####
191
192 #####
193
194 #####
195
196 #####
197
198 #####
199
200 #####
201
202 #####
203
204 #####
205
206 #####
207
208 #####
209
210 #####
211
212 #####
213
214 #####
215
216 #####
217
218 #####
219
220 #####
221
222 #####
223
224 #####
225
226 #####
227
228 #####
229
230 #####
231
232 #####
233
234 #####
235
236 #####
237
238 #####
239
240 #####
241
242 #####
243
244 #####
245
246 #####
247
248 #####
249
250 #####
251
252 #####
253
254 #####
255
256 #####
257
258 #####
259
260 #####
261
262 #####
263
264 #####
265
266 #####
267
268 #####
269
270 #####
271
272 #####
273
274 #####
275
276 #####
277
278 #####
279
280 #####
281
282 #####
283
284 #####
285
286 #####
287
288 #####
289
290 #####
291
292 #####
293
294 #####
295
296 #####
297
298 #####
299
300 #####
301
302 #####
303
304 #####
305
306 #####
307
308 #####
309
310 #####
311
312 #####
313
314 #####
315
316 #####
317
318 #####
319
320 #####
321
322 #####
323
324 #####
325
326 #####
327
328 #####
329
330 #####
331
332 #####
333
334 #####
335
336 #####
337
338 #####
339
340 #####
341
342 #####
343
344 #####
345
346 #####
347
348 #####
349
350 #####
351
352 #####
353
354 #####
355
356 #####
357
358 #####
359
360 #####
361
362 #####
363
364 #####
365
366 #####
367
368 #####
369
370 #####
371
372 #####
373
374 #####
375
376 #####
377
378 #####
379
380 #####
381
382 #####
383
384 #####
385
386 #####
387
388 #####
389
390 #####
391
392 #####
393
394 #####
395
396 #####
397
398 #####
399
400 #####
401
402 #####
403
404 #####
405
406 #####
407
408 #####
409
410 #####
411
412 #####
413
414 #####
415
416 #####
417
418 #####
419
420 #####
421
422 #####
423
424 #####
425
426 #####
427
428 #####
429
430 #####
431
432 #####
433
434 #####
435
436 #####
437
438 #####
439
440 #####
441
442 #####
443
444 #####
445
446 #####
447
448 #####
449
450 #####
451
452 #####
453
454 #####
455
456 #####
457
458 #####
459
460 #####
461
462 #####
463
464 #####
465
466 #####
467
468 #####
469
470 #####
471
472 #####
473
474 #####
475
476 #####
477
478 #####
479
480 #####
481
482 #####
483
484 #####
485
486 #####
487
488 #####
489
490 #####
491
492 #####
493
494 #####
495
496 #####
497
498 #####
499
500 #####
501
502 #####
503
504 #####
505
506 #####
507
508 #####
509
510 #####
511
512 #####
513
514 #####
515
516 #####
517
518 #####
519
520 #####
521
522 #####
523
524 #####
525
526 #####
527
528 #####
529
530 #####
531
532 #####
533
534 #####
535
536 #####
537
538 #####
539
540 #####
541
542 #####
543
544 #####
545
546 #####
547
548 #####
549
550 #####
551
552 #####
553
554 #####
555
556 #####
557
558 #####
559
560 #####
561
562 #####
563
564 #####
565
566 #####
567
568 #####
569
570 #####
571
572 #####
573
574 #####
575
576 #####
577
578 #####
579
580 #####
581
582 #####
583
584 #####
585
586 #####
587
588 #####
589
590 #####
591
592 #####
593
594 #####
595
596 #####
597
598 #####
599
600 #####
601
602 #####
603
604 #####
605
606 #####
607
608 #####
609
610 #####
611
612 #####
613
614 #####
615
616 #####
617
618 #####
619
620 #####
621
622 #####
623
624 #####
625
626 #####
627
628 #####
629
630 #####
631
632 #####
633
634 #####
635
636 #####
637
638 #####
639
640 #####
641
642 #####
643
644 #####
645
646 #####
647
648 #####
649
650 #####
651
652 #####
653
654 #####
655
656 #####
657
658 #####
659
660 #####
661
662 #####
663
664 #####
665
666 #####
667
668 #####
669
670 #####
671
672 #####
673
674 #####
675
676 #####
677
678 #####
679
680 #####
681
682 #####
683
684 #####
685
686 #####
687
688 #####
689
690 #####
691
692 #####
693
694 #####
695
696 #####
697
698 #####
699
700 #####
701
702 #####
703
704 #####
705
706 #####
707
708 #####
709
710 #####
711
712 #####
713
714 #####
715
716 #####
717
718 #####
719
720 #####
721
722 #####
723
724 #####
725
726 #####
727
728 #####
729
730 #####
731
732 #####
733
734 #####
735
736 #####
737
738 #####
739
740 #####
741
742 #####
743
744 #####
745
746 #####
747
748 #####
749
750 #####
751
752 #####
753
754 #####
755
756 #####
757
758 #####
759
760 #####
761
762 #####
763
764 #####
765
766 #####
767
768 #####
769
770 #####
771
772 #####
773
774 #####
775
776 #####
777
778 #####
779
780 #####
781
782 #####
783
784 #####
785
786 #####
787
788 #####
789
790 #####
791
792 #####
793
794 #####
795
796 #####
797
798 #####
799
800 #####
801
802 #####
803
804 #####
805
806 #####
807
808 #####
809
810 #####
811
812 #####
813
814 #####
815
816 #####
817
818 #####
819
820 #####
821
822 #####
823
824 #####
825
826 #####
827
828 #####
829
830 #####
831
832 #####
833
834 #####
835
836 #####
837
838 #####
839
840 #####
841
842 #####
843
844 #####
845
846 #####
847
848 #####
849
850 #####
851
852 #####
853
854 #####
855
856 #####
857
858 #####
859
860 #####
861
862 #####
863
864 #####
865
866 #####
867
868 #####
869
870 #####
871
872 #####
873
874 #####
875
876 #####
877
878 #####
879
880 #####
881
882 #####
883
884 #####
885
886 #####
887
888 #####
889
890 #####
891
892 #####
893
894 #####
895
896 #####
897
898 #####
899
900 #####
901
902 #####
903
904 #####
905
906 #####
907
908 #####
909
910 #####
911
912 #####
913
914 #####
915
916 #####
917
918 #####
919
920 #####
921
922 #####
923
924 #####
925
926 #####
927
928 #####
929
930 #####
931
932 #####
933
934 #####
935
936 #####
937
938 #####
939
940 #####
941
942 #####
943
944 #####
945
946 #####
947
948 #####
949
950 #####
951
952 #####
953
954 #####
955
956 #####
957
958 #####
959
960 #####
961
962 #####
963
964 #####
965
966 #####
967
968 #####
969
970 #####
971
972 #####
973
974 #####
975
976 #####
977
978 #####
979
980 #####
981
982 #####
983
984 #####
985
986 #####
987
988 #####
989
990 #####
991
992 #####
993
994 #####
995
996 #####
997
998 #####
999
1000 #####

```

- **Traceability:** FR14-DT-05, FR14-DT-07, FR14-DT-14.

BUG-07 — [FR-10 / Mobile] Server lets a user cancel a shipping order

- **Severity:** High
- **Spec:** FR-10 — when an order is `shipping`, the **User may NOT self-cancel** (admin only); FR-20 — mobile cancel only when `pending` / `confirmed`.
- **Preconditions:** an order owned by the user, driven to `shipping` (via admin API).
- **Steps (cURL):**

```

U=$(curl -s -X POST http://localhost:3000/api/login -H "Content-Type: application/json" \
  -d '{"email":"test@eshop.com","password":"Test1234!"}' | sed -E 's/.*"token":("[^"]+).*/\1/')
A=$(curl -s -X POST http://localhost:3000/api/login -H "Content-Type: application/json" \
  -d '{"email":"admin@eshop.com","password":"Admin123!"}' | sed -E 's/.*"token":("[^"]+).*/\1/')
OID=$(curl -s -X POST http://localhost:3000/api/checkout -H "Authorization: Bearer $U" \
  -H "Content-Type: application/json" -d '{"total_amount":100000,"shipping_address":"x"}' \
  | sed -E 's/.*"orderId":([0-9]+).*/\1/')
curl -s -X PUT http://localhost:3000/api/admin/orders/$OID/status -H "Authorization: Bearer $A" \
  -H "Content-Type: application/json" -d '{"status":"confirmed"}' >/dev/null
curl -s -X PUT http://localhost:3000/api/admin/orders/$OID/status -H "Authorization: Bearer $A" \
  -H "Content-Type: application/json" -d '{"status":"shipping"}' >/dev/null
curl -s -o /dev/null -w "%{http_code}\n" -X PUT http://localhost:3000/api/orders/$OID/cancel \
  -H "Authorization: Bearer $U" # user cancels the shipping order

```

- **Expected:** reject (4xx) — user cannot cancel once `shipping`.
- **Actual:** 200 — the cancel succeeds. `/api/orders/:id/cancel` only rejects `delivered` / `canceled`; `shipping` falls through and is cancelled. The mobile UI hides the button (L1), so this defect is only visible at the **API layer (L2)**.
- **Evidence:**

```
182 #####
183
184 ### BUG-07a — user creates an order
185 # @name checkout07
186 Send Request
187 POST {{baseUrl}}/api/checkout
188 Authorization: Bearer {{userLogin.response.body.$.token}}
189 Content-Type: application/json
190 { "total_amount": 100000, "shipping_address": "7 Test St" }
191
192 ### BUG-07b — admin: pending -> confirmed
193 Send Request
194 PUT {{baseUrl}}/api/admin/orders/{{checkout07.response.body.$.orderId}}/status
195 Authorization: Bearer {{adminLogin.response.body.$.token}}
196 Content-Type: application/json
197 { "status": "confirmed" }
198
199 ### BUG-07c — admin: confirmed -> shipping
200 Send Request
201 PUT {{baseUrl}}/api/admin/orders/{{checkout07.response.body.$.orderId}}/status
202 Authorization: Bearer {{adminLogin.response.body.$.token}}
203 Content-Type: application/json
204 { "status": "shipping" }
205
206 ### BUG-07d — USER cancels the shipping order (ACTUAL: 200)
207 Send Request
208 PUT {{baseUrl}}/api/orders/{{checkout07.response.body.$.orderId}}/cancel
209 Authorization: Bearer {{userLogin.response.body.$.token}}
```

```
1 HTTP/1.1 200 OK
2 X-Powered-By: Express
3 Access-Control-Allow-Origin: *
4 Content-Type: application/json; charset=utf-8
5 Content-Length: 41
6 ETag: W/"29-WJTbET4UbXIJ4W57wKVOLCE4cI"
7 Date: Mon, 06 Jul 2026 07:23:40 GMT
8 Connection: close
9
10 {
11   "message": "Order canceled successfully"
12 }
```

- **Traceability:** FR10-DT-07 , FR10-BVA-06 .

BUG-05 — [FR-14] Empty / whitespace category name accepted

- **Severity:** Medium
- **Spec:** FR-14 — "Tên danh mục là bắt buộc, không được để trống" (name required, non-empty).
- **Preconditions:** admin token.
- **Steps (cURL):**

```
A=$(curl -s -X POST http://localhost:3000/api/login -H "Content-Type: application/json" \
-d '{"email":"admin@eshop.com","password":"Admin123!"}' | sed -E 's/.*"token":"([^\"]+)".*/\1/')
curl -s -o /dev/null -w "%{http_code}\n" -X POST http://localhost:3000/api/categories \
-H "Authorization: Bearer $A" -H "Content-Type: application/json" -d '{"name":""}'
curl -s -o /dev/null -w "%{http_code}\n" -X POST http://localhost:3000/api/categories \
-H "Authorization: Bearer $A" -H "Content-Type: application/json" -d '{"name":"  "'}
```

- **Expected:** reject — name required, not empty.
- **Actual:** 200 — an empty (and whitespace-only) category is created. No non-empty validation.
- **Evidence:**

```
13
14
15 #####
16 # BUG-05 [Medium, FR-14] Empty / whitespace category name
17 # EXPECT: reject - name required, non-empty
18 # ACTUAL: 200 "Category created"
19 #####
20
21 ### BUG-05a - empty name (ACTUAL: 200 created)
22 Send Request
23 POST {{baseUrl}}/api/categories
24 Authorization: Bearer {{adminLogin.response.body.$.token}}
25 Content-Type: application/json
26 { "name": "" }
27
28 ### BUG-05b - whitespace-only name (ACTUAL: 200 created)
29 Send Request
30 POST {{baseUrl}}/api/categories
31 Authorization: Bearer {{adminLogin.response.body.$.token}}
32 Content-Type: application/json
33 { "name": "  " }
34
```

```
1 HTTP/1.1 200 OK
2 X-Powered-By: Express
3 Access-Control-Allow-Origin: *
4 Content-Type: application/javascript; charset=utf-8
5 Content-Length: 37
6 ETag: W/"25-1DXERNwNupPyY5BRzX4DPoPDVls"
7 Date: Mon, 06 Jul 2026 07:21:17 GMT
8 Connection: close
9
10 {
11   "message": "Category created",
12   "id": 5
13 }
```

- **Traceability:** FR14-DT-03 , FR14-DT-04 , FR14-BVA-01 , FR14-BVA-04 .

BUG-08 — [FR-10 / Admin] Admin can move a canceled order to delivered

- **Severity:** High
- **Spec:** FR-10 — delivered and canceled are **final states** (no transition out).
- **Preconditions:** a canceled order; admin token.
- **Steps (cURL):** checkout as user → admin sets canceled → admin sets delivered (full script in docs/issues/bug-08.md).
- **Expected:** reject (4xx) — canceled is terminal.
- **Actual:** 200 "Order status updated" . The admin handler explicitly whitelists canceled → delivered (if (currentStatus === "canceled" && status === "delivered") isValidTransition = true;), resurrecting a terminal order (can also inflate delivered-revenue).
- **Evidence:**


```
#####
### BUG-08a — user creates an order
# @name checkout08
Send Request
POST {{baseUrl}}/api/checkout
Authorization: Bearer {{userLogin.response.body$.token}}
Content-Type: application/json

{ "total_amount": 100000, "shipping_address": "8 Test St" }

### BUG-08b — admin: pending -> canceled
Send Request
PUT {{baseUrl}}/api/admin/orders/{{checkout08.response.body$.orderId}}
Authorization: Bearer {{adminLogin.response.body$.token}}
Content-Type: application/json

{ "status": "canceled" }

### BUG-08c — admin: canceled -> delivered (ACTUAL: 200, should be 404)
Send Request
PUT {{baseUrl}}/api/admin/orders/{{checkout08.response.body$.orderId}}
Authorization: Bearer {{adminLogin.response.body$.token}}
Content-Type: application/json

{ "status": "delivered" }
```

```
1 HTTP/1.1 200 OK
2 X-Powered-By: Express
3 Access-Control-Allow-Origin: *
4 Content-Type: application/json; charset=utf-8
5 Content-Length: 34
6 ETag: W/"22-51mpS3VNAfERw0NLwrZGnxUOWZo"
7 Date: Mon, 06 Jul 2026 07:25:30 GMT
8 Connection: close
9
10 {
11   "message": "Order status updated"
12 }
```

- **Traceability:** FR10-ADM-01 (controls FR10-ADM-02, FR10-ADM-03 pass).
- **Note:** this is the admin-side final-state defect the FR-10 *mobile* redesign stopped covering; re-added as an admin auto-case.

BUG-09 — [FR-14 / FR-15] Deleting a category orphans its products

- **Severity:** Medium
- **Spec:** FR-15 — a product's category "phải chọn từ danh sách có sẵn" (must reference a valid, available category). Deleting a category with no integrity guard breaks that invariant.
- **Preconditions:** admin token.
- **Steps (cURL):** create category → create a product in it → delete the category → the product still references the deleted id (full script in docs/issues/bug-09.md).
- **Expected:** delete prevented, or products reassigned/removed — no product left referencing a non-existent category.
- **Actual:** DELETE returns 200 "Category deleted"; the product is **orphaned** (its `category_id` no longer exists in GET /api/categories). Silent data-integrity corruption.
- **Evidence:**

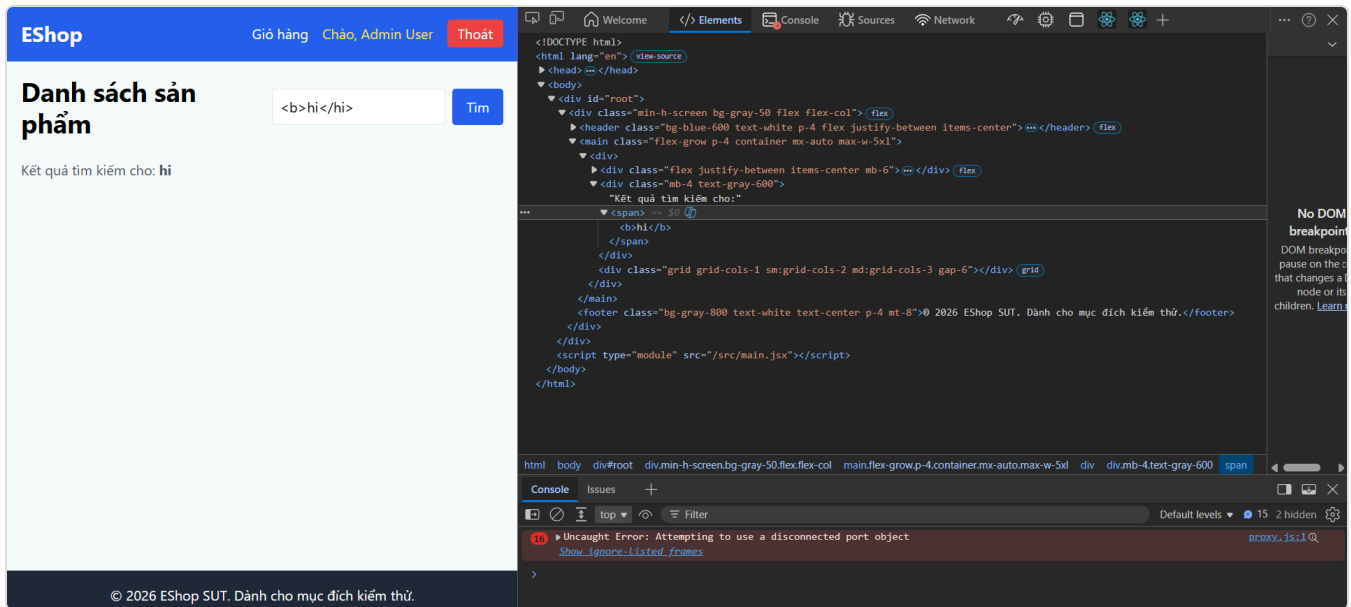

```
47
48 ### BUG-09a — create a throwaway category
49 # @name cat09
50 Send Request
51 POST {{baseUrl}}/api/categories
52 Authorization: Bearer {{adminLogin.response.body.$.token}}
53 Content-Type: application/json
54 { "name": "TempCat-09" }
55
56 ### BUG-09b — create a product in that category
57 # @name prod09
58 Send Request
59 POST {{baseUrl}}/api/products
60 Authorization: Bearer {{adminLogin.response.body.$.token}}
61 Content-Type: application/json
62 { "name": "Orphan-Test", "price": 1000, "description": "", "image": "" }
63
64 ### BUG-09c — delete the category (ACTUAL: 200 "Category deleted")
65 Send Request
66 DELETE {{baseUrl}}/api/categories/{{cat09.response.body.$.id}}
67 Authorization: Bearer {{adminLogin.response.body.$.token}}
68
69 ### BUG-09d — category is now gone (should NOT list cat09's id)
70 Send Request
71 GET {{baseUrl}}/api/categories
72
73 ### BUG-09e — product still references the deleted category_id
74 Send Request
75 GET {{baseUrl}}/api/products/{{prod09.response.body.$.id}}
```

```
1 HTTP/1.1 200 OK
2 X-Powered-By: Express
3 Access-Control-Allow-Origin: *
4 Content-Type: application/json; charset=utf-8
5 Content-Length: 91
6 ETag: W/"5b-xuqmPZxakuDP5F/Fc5S7/uNX1Vs"
7 Date: Mon, 06 Jul 2026 07:26:49 GMT
8 Connection: close
9
10 {
11   "id": 6,
12   "name": "Orphan-Test",
13   "price": "1000",
14   "description": "",
15   "imageUrl": "",
16   "category_id": 6
17 }
```

- **Traceability:** FR14-INTEG-01 .

BUG-10 — [FR-05] Reflected XSS in web product search

- **Severity:** Critical
- **Spec:** FR-05 R5 — search term "hiển thị an toàn (không render HTML)"; **SEC-04** — escape user input, no direct `innerHTML` .
- **Preconditions:** web app running (:5173).
- **Steps:** on the home page search `<b>hi</b>`, then `<img src=x onerror=alert(1)>` .
- **Expected:** term shown as literal escaped text; no HTML rendered; no JS executes.
- **Actual:** the term is rendered via `dangerouslySetInnerHTML` (`frontend-web/src/pages/Home.jsx:64`). `<b>hi</b>` renders **bold**; `<img ... onerror=alert(1)>` **executes** → reflected XSS. Same unsafe render on the no-results view (:61-66) and on server error strings (:68-72).
- **Evidence:**

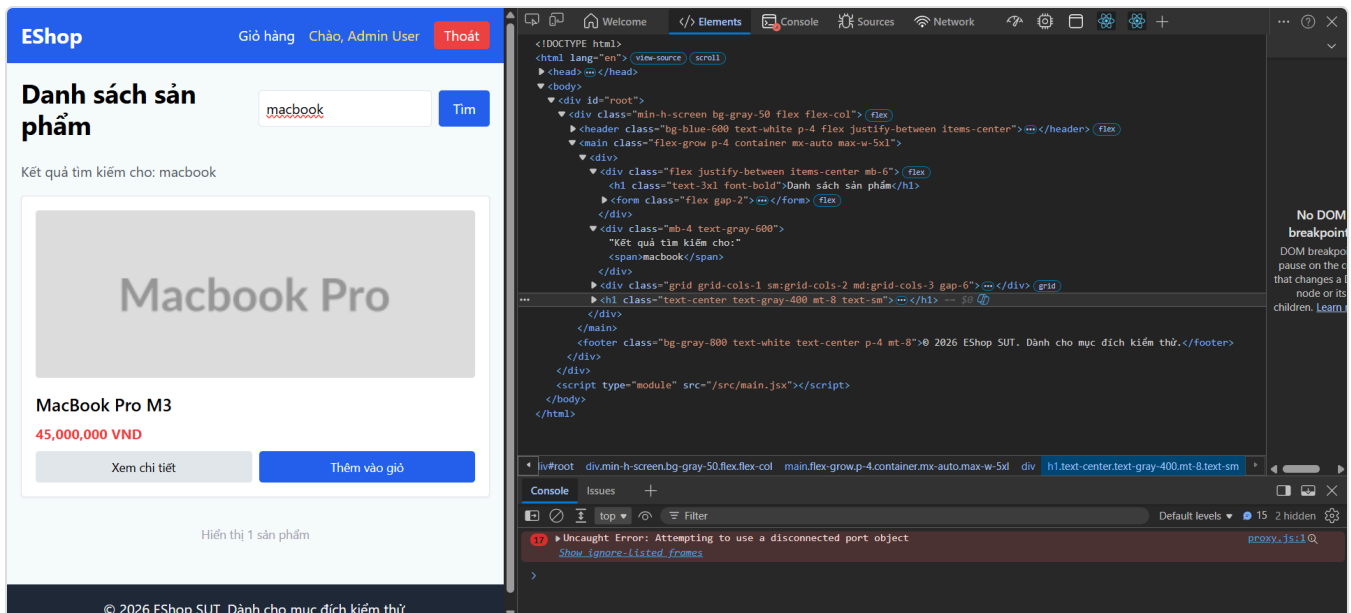


- **Traceability:** FR05-DT-09 , FR05-DT-10 , FR05-DT-11 , FR05-DT-17 . (Verified statically in docs/manual-ui-verification.md .)

FR-05 listing GUI defects (frontend-web/src/pages/Home.jsx) — originally one bundle, now split into 5 separate Low issues (BUG-11, BUG-14, BUG-15, BUG-16, BUG-17).

BUG-11 — [FR-05] Listing page has two <h1>

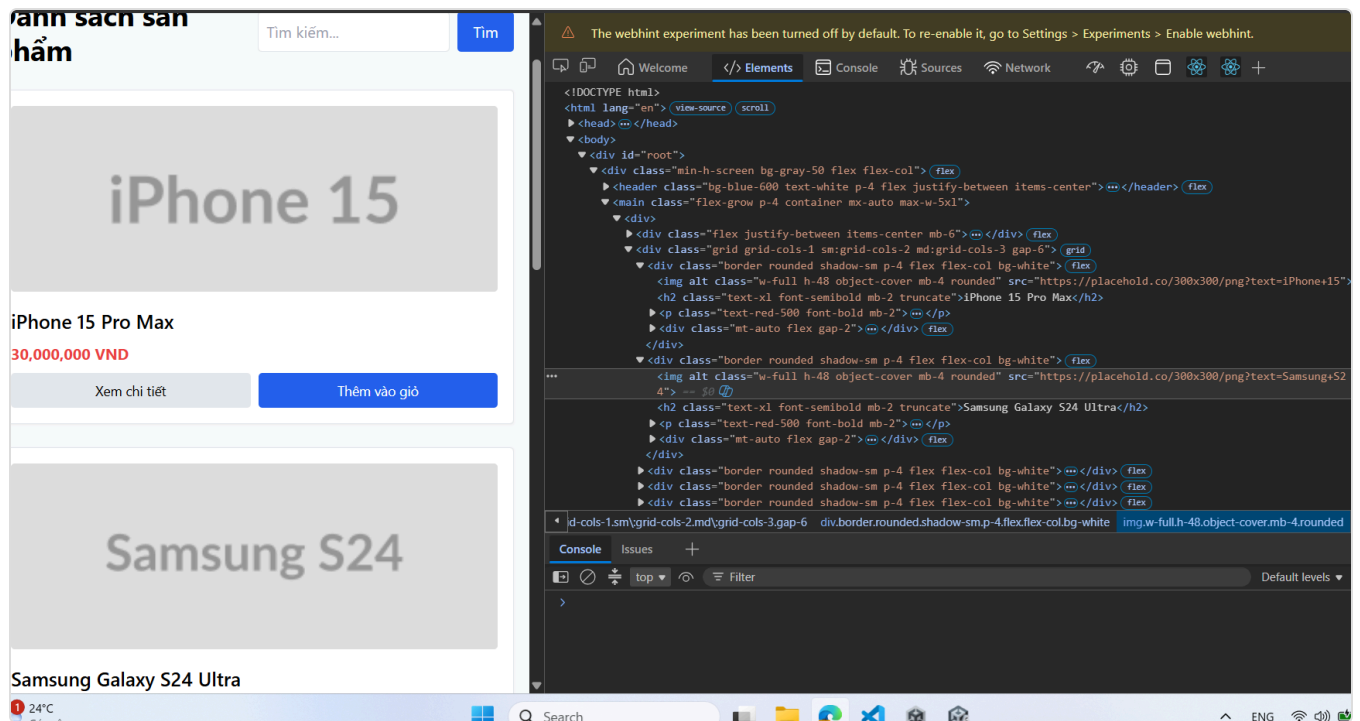
- **Severity:** Low · **Issue:** #11
- **Spec:** FR-05 R8 / FR-21 — exactly one <h1> per page.
- **Actual:** document.querySelectorAll('h1').length → 2 ("Danh sách sản phẩm" Home.jsx:43
 - "Hiển thị N sản phẩm" Home.jsx:110).
- **Evidence:**



- **Traceability:** FR05-DT-01 (h1 sub-check).

BUG-14 — [FR-05] Product images have empty alt

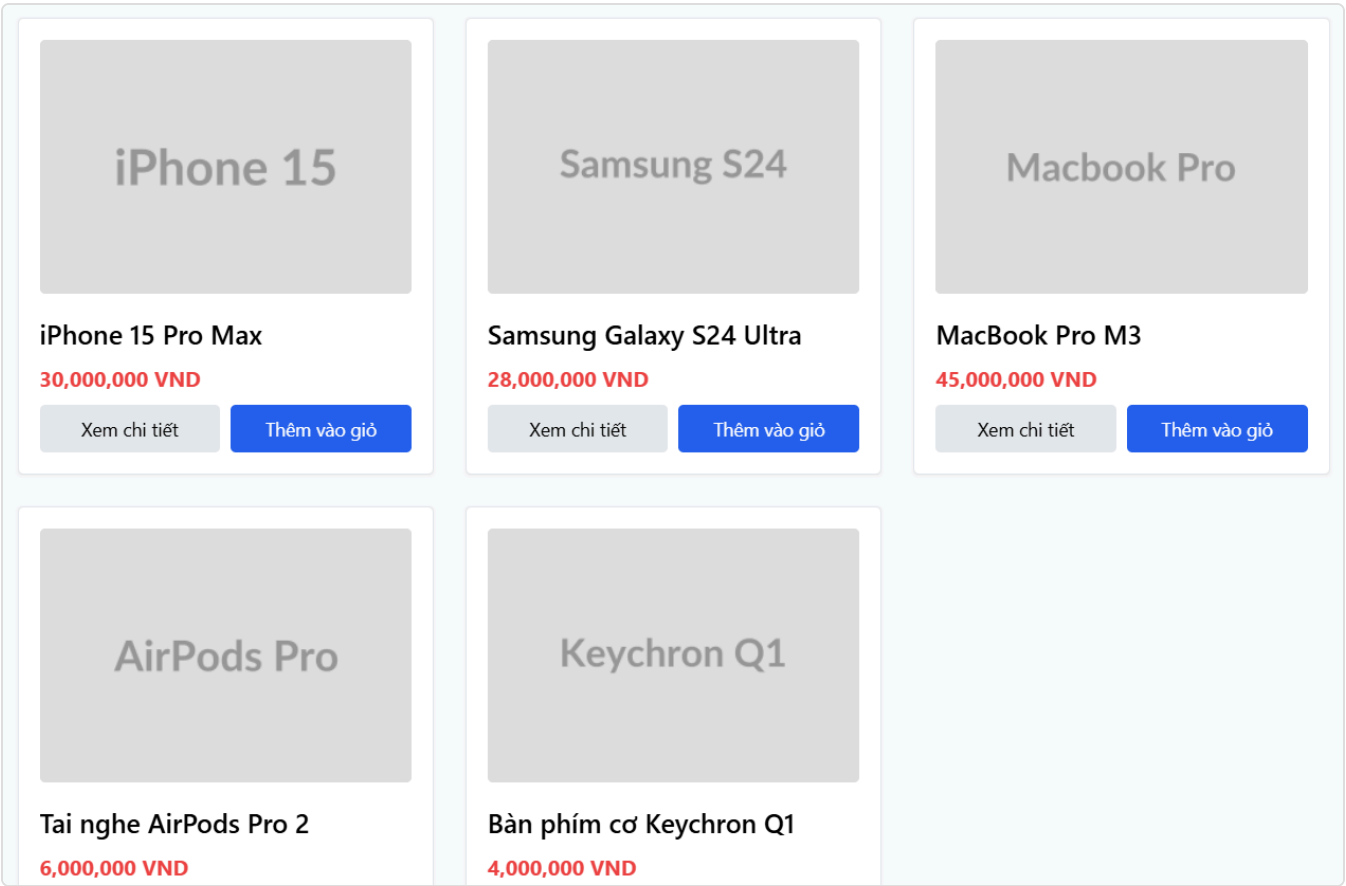
- **Severity:** Low · **Issue:** #15
- **Spec:** FR-05 R2 / FR-24 — descriptive, non-empty alt .
- **Actual:** alt="" on every product image (Home.jsx:82).
- **Evidence:**



- **Traceability:** FR05-DT-01 (alt sub-check).

BUG-15 — [FR-05] Price shows "VND" instead of đ

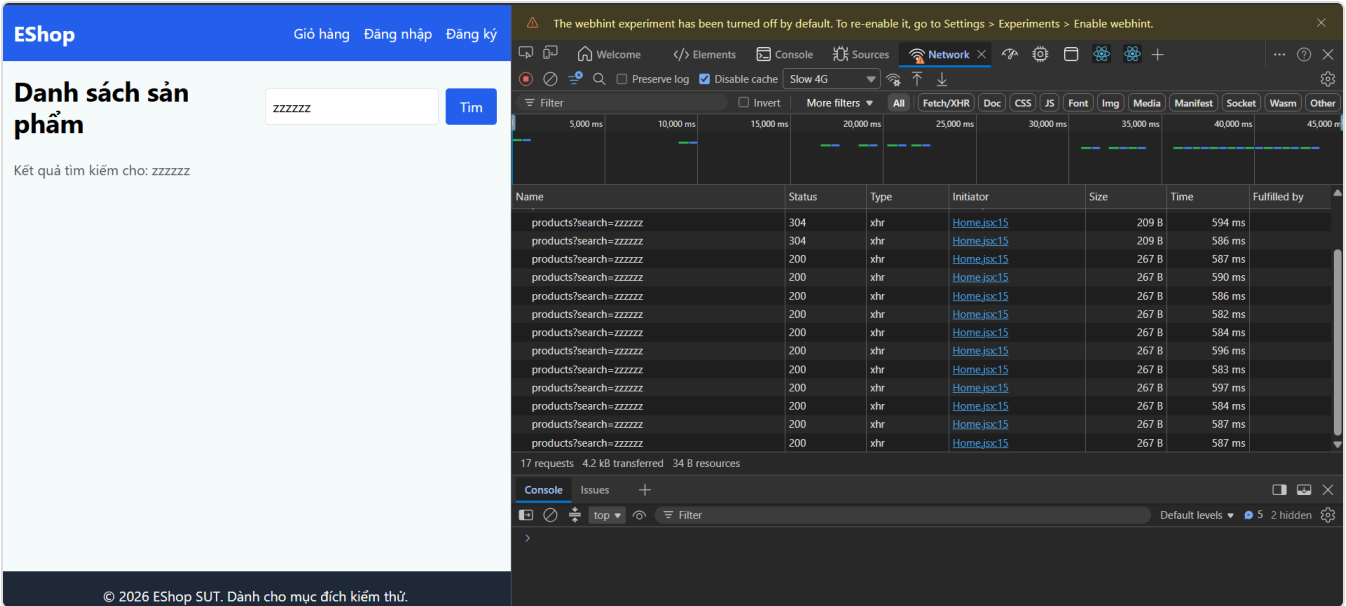
- **Severity:** Low · **Issue:** #16
- **Spec:** FR-05 R3 / FR-21 — use đ with thousands separator.
- **Actual:** shows ... VND (Home.jsx:87 — {Number(p.price).toLocaleString()} VND).
- **Evidence:**



· **Traceability:** FR05-DT-01 (price sub-check).

BUG-16 — [FR-05] No loading state while fetching

- **Severity:** Low · **Issue:** #17
- **Spec:** FR-05 R6 — show a loading state during fetch.
- **Actual:** no loading flag; nothing renders during the await (Home.jsx:12-33).
- **Evidence:**



· **Traceability:** FR05-DT-08 .

BUG-17 — [FR-05] No empty-state message when search returns no results

- **Severity:** Low · **Issue:** #18
- **Spec:** FR-05 R7 / FR-24 — "Khi không có kết quả tìm kiếm phải hiển thị thông báo empty state phù hợp".
- **Actual (browser-verified):** search `zzzzz` → 0 results, blank area, **no message** (`Home.jsx:74-107` ; the status line `:109` is gated on `products.length > 0`).
- **Evidence:**



- **Traceability:** `FR05-DT-07` , `FR05-DT-16` .

BUG-12 — [FR-09] Coupon code lookup is case-sensitive

- **Severity:** Low
- **Spec:** FR-09 — does not *mandate* case-insensitive codes, but the API is inconsistent with the case-insensitive product search and reports a valid coupon (different case) as non-existent.
- **Preconditions:** none (seeded `SAVE10`).
- **Steps (cURL):** `POST /api/apply-coupon {"code":"save10","total_amount":500000,"user_id":2}` .
- **Expected:** applies the coupon (`save10` = `SAVE10`), or at least consistent with the case-insensitive `LIKE` used by product search.
- **Actual:** 404 "Mã giảm giá không tồn tại..." . The query `WHERE code = ?` uses SQLite's default **BINARY** collation, so `'save10' != 'SAVE10'` . Only masked in the UI because the frontends `.toUpperCase()` before sending (`frontend-mobile/App.js:366`). Fix: `WHERE code = ? COLLATE NOCASE` .
- **Evidence:**

```

102 #####
103 # BUG-12 [Low, FR-09] Coupon code lookup is case-sensitive (save10 != SAVE10)
104 # EXPECT: applies (same coupon), or at least consistent with search
105 # ACTUAL: 404 "Mã giảm giá không tồn tại..." (WHERE code = ? is BINARY)
106 #####
107
108 ### BUG-12 - lowercase code
109 Send Request
110 POST {{baseUrl}}/api/apply-coupon
111 Content-Type: application/json
112 { "code": "save10", "total_amount": 500000, "user_id": {{userId}} }
113
114
115 #####
116 # BUG-95 [Medium, FR-14] Empty / whitespace category name accepted
117 # EXPECT: reject - name required, non-empty
118 # ACTUAL: 200 "Category created"

```

- ```

1 HTTP/1.1 404 Not Found
2 X-Powered-By: Express
3 Access-Control-Allow-Origin: *
4 Content-Type: application/json;
 charset=utf-8
5 Content-Length: 79
6 ETag: W/"4f-Zi25GXkQG92bS4E0xPG
 gD4Fb01I"
7 Date: Mon, 06 Jul 2026 07:07:49
 GMT
8 Connection: close
9
10 {
11 "error": "Mã giảm giá không t
 ồn tại hoặc đã bị vô hiệu hóa"
12 }

```

### BUG-13 — [FR-10] Non-admin can change order status (missing admin-role check)

- **Severity:** High
- **Spec:** FR-12 / **SEC-03** — `/api/admin/*` must require a valid JWT **and** `role='admin'` . `PUT /api/admin/orders/:id/status` drives the FR-10 state machine, so it must be admin-only.
- **Preconditions:** a normal (non-admin) user token; any order.
- **Steps (cURL):** login as user → checkout → `PUT /api/admin/orders/:id/status` with the **user** token (full script in `docs/issues/bug-13.md` ).
- **Expected:** `403 Forbidden` .
- **Actual:** `200 "Order status updated"` — a normal user can move any order through the state machine. Route uses `authenticateToken` only ( `server.js:525` ), no role check. Same class as BUG-06; `GET /api/admin/orders` ( `:510` ) has the same gap (any user lists all orders).
- **Evidence:**

```
docs > @api-bug-tests.http > ...
154 #####
155 # BUG-13 [High, FR-10] Non-admin can change order status (missing role check)
156 # Run 13a then 13b.
157 # EXPECT (13b): 403 Forbidden
158 # ACTUAL: 200 "Order status updated" - non-admin drives the state machine
159 #####
160
161 ### BUG-13a - create a pending order as the user
162 # @name checkout13
163 Send Request
164 POST {{baseUri}}/api/checkout
165 Authorization: Bearer {{userLogin.response.body.$.token}}
166 Content-Type: application/json
167 { "total_amount": 10000, "shipping_address": "13 Test St" }
168
169 ### BUG-13b - user (non-admin) drives admin status endpoint (ACTUAL: 200)
170 Send Request
171 PUT {{baseUri}}/api/admin/orders/{{checkout13.response.body.$.orderId}}/status
172 Authorization: Bearer {{userLogin.response.body.$.token}}
173 Content-Type: application/json
174 { "status": "confirmed" }
175
176
```

- ```
1 HTTP/1.1 200 OK
2 X-Powered-By: Express
3 Access-Control-Allow-Origin: *
4 Content-Type: application/json;
  charset=utf-8
5 Content-Length: 34
6 ETag: W/"22-51mpS3VNAfERw0NLwRzG
  nxUOWZo"
7 Date: Mon, 06 Jul 2026 07:39:57
  GMT
8 Connection: close
9
10 {
11   "message": "Order status updat
    ed"
12 }
```

Probe findings worth escalating (not filed)

- **Silent no-op:** deleting a non-existent / non-numeric category id returns 200 "Category deleted" (FR14-DT-08 , FR14-BVA-14).